



**UNIVERSIDAD TECNOLÓGICA
DE QUERÉTARO**

Alumna:

Vasquez Noyola Andrea

Grupo:

IDGS17

Matrícula:

2023148002

Materia:

Seguridad en el Desarrollo de Aplicaciones

Práctica 2 - Parte 2

En esta fase final, se creó la rama secure para aplicar controles de mitigación contra las vulnerabilidades detectadas en el entorno local VulnerableApp. Las acciones correctivas incluyeron:

- Reemplazo de SQL estático por LINQ: Eliminando el riesgo de Inyección SQL en las búsquedas.
- Implementación de Hashing criptográfico: Transición de contraseñas en texto plano a hashes seguros generados con el algoritmo BCrypt, garantizando la confidencialidad de las credenciales incluso si la base de datos es comprometida.
- Refactorización de Autenticación: Eliminación de credenciales hardcodeadas (admin/admin) y establecimiento de un flujo de verificación de hashes.
- Codificación de salida (Output Encoding): Reemplazo de @Html.Raw por @Html.Encode en las vistas para neutralizar scripts maliciosos (XSS).
- Control de Acceso Horizontal: Adición de validaciones de sesión (HttpContext.Session.GetInt32("UserId")) en los controladores de la API para prevenir escalamiento de privilegios y ataques IDOR, asegurando que un usuario solo acceda a sus propios registros.

Tabla Comparativa Final

Vulnerabilidad	Comportamiento Anterior (Rama main)	Comportamiento Remediado (Rama secure)	Método de Mitigación Aplicado
SQL Injection	Payload ' OR '1'='1 exponía todos los usuarios.	La búsqueda evalúa el input como texto literal; no devuelve resultados.	Uso de consultas parametrizadas vía Entity Framework LINQ (.Contains()).
Auth Bypass	Acceso permitido con admin/admin o inyección SQL.	Acceso denegado; muestra mensaje "Credenciales inválidas".	Eliminación de credenciales en duro y validación segura contra base de datos.

Contraseñas	Guardadas y transmitidas en texto plano.	Almacenadas como cadenas ilegibles y seguras.	Implementación de BCrypt.Net para el hash de contraseñas.
XSS	Ejecución nativa de <script> alertando al usuario.	El script se renderiza como texto inofensivo en pantalla.	Uso de @Html.Encode() para sanitizar la salida HTML.
IDOR	Acceso a IDs de terceros y exposición masiva de datos.	Respuesta HTTP 403 (Forbidden) al solicitar datos de terceros.	Validación de UserId en sesión actual frente al ID solicitado.